

IBM BOB 2.0 HACKATHON · WATERLOO WORKFLOW LAB

PreFlight

Pre-merge diff risk scanner. Drop a `git diff` in, get an A-F risk report out — 100% in your browser.

Local-first · zero install · MIT

The problem: diffs get skimmed

- The same cheap mistakes keep shipping: **pasted keys**, debug leftovers, unresolved conflict markers, migrations with no rollback, undeclared env vars, lockfile drift, missing tests.
- Trivial to catch. **Expensive when missed** — credential leaks, broken deploys, irreversible migrations.
- Incumbent scanners need CI plumbing, repo permissions, config files. **Nothing lives in the last 30 seconds before push.**

The hero flow

- Paste or drop `git diff`, `git show`, `format-patch`, GitHub `.patch`.
- 13 focused rules run locally in <10 ms.
- Get a grade, file:line findings with fixes, a reviewer checklist, and a markdown report for the PR.

F

the built-in toxic sample: 26 findings,
3 critical — caught in one click

How it works

```
git diff → parser → 13 rules → A–F score → markdown report  
(multi-file, /dev/null, renames, hunks, binary)
```

- Secrets (AWS, GitHub, Stripe, Slack, JWT, DB URLs) + high-entropy credential assignments
- Conflict markers · debug leftovers · TODO/FIXME · sensitive paths
- Manifest↔lockfile drift · migrations without rollback · undeclared env vars · missing tests · diff size
- **Local-first is the security model** — diffs contain secrets; they never leave the browser.

Business value

- **Proven market:** GitGuardian, TruffleHog, Danger.js, SAST vendors — billions spent on shift-left security and review tooling.
- **Unserved wedge:** the pre-CI moment — solo devs and small teams, zero install, zero auth, paste-and-go.
- **Revenue model:** free web scanner → paid team tier (CI gate, custom rule packs via `.preflight.yml`, org dashboards). Classic open-core.
- **Originality:** a shareable A-F verdict on a pasted diff — not another CI bot.

Built with AI dev partners

- **Devin** built the overnight MVP under automation: parser, rule engine, scoring, UI, 44-test suite — real commits, real history.
- **IBM Bob Shell 2.0** picked up the repo from there: a new commented-out-code rule, a dogfooding PR-comment GitHub Action, a scoring audit + docs. Full stream-json transcripts in `bob_sessions/shell-*`.
- One codebase, two AI partners, an honest ledger: `docs/B0B_USAGE.md`. Bob IDE evidence lands in `bob_sessions/ide/` once sessions complete.

Where it goes next

- Custom rule packs (`.preflight.yml`), OpenAPI breaking-change mode.
- Team dashboards + severity-threshold presets.
- **Shipped during the event:** a PR-comment GitHub Action (`dogfood.yml`) — the scanner grades its own PRs.

```
github.com/sharonbasovich/preflight · MIT · npm run dev
```